

DigiT — Secure Onboarding & Sign-in

A four-stage, passwordless, device-bound sign-up · v1.0

DigiT onboards a new client through **four secure stages** — identity, company, role and access — and deliberately uses **no client-chosen email/password**. Instead, DigiT generates a **one-time alphanumeric passcode**, emails it to the registered company address, and the user enters it once to **lock DigiT to that device**. The code is consumed and device-bound, so it can never be reused or replayed on another device. If the code is lost, sign-in falls back to **SSO** (Google, Microsoft, Apple or GitHub). The result is a passwordless, phishing-resistant model where access is tied to a verified person, a verified company, and a trusted device.

DigiT sign-up — four secure stages

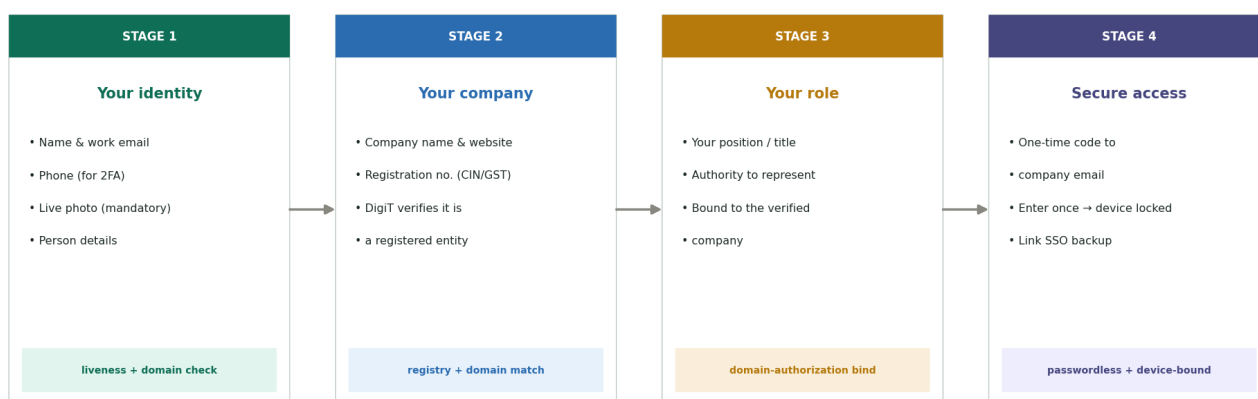


Figure 1 — The four sign-up stages and what each one collects and verifies.

The four sign-up stages, in detail

Stage 1 — Your identity (the person)

Collected

Full name, work email (must be a company address), phone number (for 2FA & alerts), and a **mandatory photo**, plus basic person details.

What happens

You complete a short form and capture a **live photo** on screen. This work email becomes the address the one-time access code is later sent to.

Secured by

Free / disposable email domains are blocked. The photo is a **live selfie with liveness detection** (not a static upload), so it proves a real person and cannot be a borrowed image — optionally matched to a government ID for KYC-grade assurance.

Stage 2 — Your company (registered & verified)

Collected

Company legal name, registration number (CIN / GST / local equivalent), country, registered address, and website.

What happens

DigiT **verifies the company is a real registered entity** by checking it against official business registries (e.g. MCA / CIN and GST in India), and confirms the website / email domain belongs to it.

Secured by

Registry verification rejects unregistered or shell entities. A **domain-ownership check** plus a requirement that the Stage 1 email domain **matches the verified company domain** stops someone registering a company they have no connection to.

Stage 3 — Your role (position & authority)

Collected

The person's **position / title** in the company and their authority to represent or onboard it.

What happens

DigiT **binds the verified person to the verified company** through the matching email domain. Higher-privilege roles (owner / admin) can require an extra approval, such as confirmation from an existing company admin.

Secured by

Domain-authorization binding, role-based provisioning, and rate-limiting / anomaly checks that block mass or abusive sign-ups.

Stage 4 — Secure access (the passwordless credential)

Collected

Nothing typed by you except the one-time code. No password is ever created or stored.

What happens

DigiT generates a **one-time alphanumeric passcode** and emails it to your company address. You enter it **once** on this device, which enrolls and **locks DigiT to this device** (a device-bound credential / passkey is created). You also link one or more **SSO backups** (Google / Microsoft / Apple / GitHub).

Secured by

The code is **one-time and consumed** the moment it is used; it **binds to this one device** and can never be replayed or used elsewhere (anti-replay); no password exists to steal; and SSO is enrolled as the recovery path.

The authentication model — how sign-in works

No password is ever chosen or typed. Access depends on a trusted device, with SSO as the fallback.



Figure 2 — The sign-in decision: a recognized device signs in silently; an unrecognized device hits a deliberate dead-end, with SSO (or re-enrolment) as the only way forward.

- **Trusted (enrolled) device** — you are signed in **silently** via the device credential and an optional biometric — you never type an email or password.
- **The one-time code** — generated once, a mix of letters and numbers, emailed to your company address, used once at enrolment, bound to that one device, and never reusable.
- **A new / unrecognized device** — you see only the standard **email + password** screen — and because you have no password, there is no way through, and there is **deliberately no field to re-enter the one-time code** (this is the anti-replay protection). Your options are to sign in with a linked **SSO** provider, or to sign up again.
- **If the code is lost or cannot be retrieved** — DigiT presents the **SSO dropdown** (Google / Microsoft / Apple / GitHub); you pick one, and from then on **that SSO method is your sign-in**.

Key screens

The image displays two side-by-side mockups of user interface screens for a secure onboarding and sign-in process.

Left Screen: Stage 4 — your one-time access code

- Header:** Stage 4 — your one-time access code
- Section:** Secure your access
- Text:** We emailed your one-time code to **you@yourcompany.com**
- Code Display:** A purple box containing the code **7 K 2 P – 9 Q X M – 4 A 1 T**
- Text:** Enter it once to lock this device:
- Input Field:** A text box with the placeholder "enter code..."
- Text:** Works once · on this device only · keep it safe
- Section:** Link a backup sign-in:
- Buttons:** Four buttons labeled Google, Microsoft, Apple, and GitHub.
- Button:** A large dark blue button labeled Secure this device.

Right Screen: Signing in on a NEW device

- Header:** Signing in on a NEW device
- Section:** Welcome back
- Form:** Email and Password input fields. The email field contains "you@yourcompany.com" and the password field contains "*****".
- Message:** A red box with the text "This device isn't recognized · no password exists".
- Section:** Lost your passcode? Sign in with:
- Form:** A dropdown menu labeled "Choose a provider" with a downward arrow.
- Buttons:** Four buttons labeled Google, Microsoft, Apple, and GitHub.
- Text:** ... or Sign up again

Figure 3 — Left: the Stage 4 one-time code screen. Right: the new-device screen — the email + password fields lead nowhere, and the only way in is the SSO dropdown or signing up again.

Stepwise summary — for better understanding

1. **Sign up** → **Stage 1:** enter your details and capture a live photo.
 2. **Stage 2:** enter your registered company; DigiT verifies it against official registries.
 3. **Stage 3:** state your position; DigiT confirms your email domain matches the verified company.
 4. **Stage 4:** DigiT emails a one-time alphanumeric code to your company address; you enter it once, which locks DigiT to this device, and you link an SSO backup.
 5. **From now on, on this device,** you are signed in automatically — no password, secured by the device credential and biometric.
 6. **The code is now used up** — it will not work again, and not on any other device.
 7. **On a new device,** you will see only an email + password screen (which you do not have), with no field for the code — use your linked SSO option, or sign up again.
 8. **Lost the code?** DigiT shows the SSO dropdown (Google / Microsoft / Apple / GitHub); pick a provider and that becomes your sign-in method.
-

Security & practical notes

To make this robust in production — recommendations on top of your design.

- **Implement device binding as passkeys / WebAuthn** — the phishing-resistant, hardware-backed way — so the one-time code creates a real cryptographic device credential, not just a flag. A device-bound key in secure storage is the fallback.
- **Make the photo a live selfie with liveness detection** — this is the anti-spoof version; pair it with ID matching if you need KYC-grade identity assurance.
- **Have a manual-review fallback for company verification** — registry coverage varies (MCA / GST in India; equivalents elsewhere) — allow a human check for entities an API cannot confirm.
- **Consider softening the new-device dead-end for legitimate users** — leading with SSO, and offering a fresh one-time code to the company email (email possession is itself strong proof), avoids fully locking out someone who simply switched devices — while still blocking anyone who only intercepted the old code. Your strict version is the most locked-down; this is the more forgiving variant.
- **Standard hardening** — log every auth event, rate-limit attempts, encrypt in transit and at rest, keep tenant isolation (RLS), and require the SSO account's email to match the verified company domain.